FACULTAD DE DEFENSA NACIONAL (FADENA)
LICENCIATURA EN CIBERDEFENSA
ASIGNATURA: TECNOLOGÍA OPERATIVA (2026)
UNIDAD 3: SISTEMAS DE SUPERVISIÓN Y SECTORES CRÍTICOS

DOCUMENTO DE CATEDRA N 12

TEMA: PROTOCOLO MODBUS: MODELO DE DATOS, FUNCTION CODES Y PERFIL DE SEGURIDAD

Apertura: El protocolo que no conoce al adversario

En 2015, investigadores de la firma Positive Technologies publicaron un estudio sobre la exposición de sistemas de control industrial en internet. Utilizando el motor de búsqueda Shodan para identificar dispositivos con el puerto TCP 502 abierto — el puerto estándar de Modbus TCP — encontraron más de 7.000 dispositivos accesibles públicamente desde internet que respondían a consultas Modbus. Entre ellos: PLCs de plantas de tratamiento de agua, sistemas de control de edificios en hospitales y universidades, y controladores de subestaciones eléctricas. Muchos de estos dispositivos respondían a cualquier consulta, sin autenticación, sin registro, sin limitación.

El dato estadístico es revelador, pero la razón técnica es más importante: Modbus fue diseñado en 1979 por Modicon para comunicar PLCs en redes de fábrica privadas y físicamente aisladas. En ese contexto, la autenticación era innecesaria — si alguien podía acceder al bus de campo, ya había pasado la valla perimetral física de la instalación. El protocolo fue optimizado para velocidad, determinismo y simplicidad. Cuatro décadas después, ese mismo protocolo sin modificación fundamental opera en infraestructuras conectadas a internet.

Comprender Modbus no es solo comprender un protocolo: es comprender la lógica de diseño de toda la primera generación de protocolos industriales, que asumían un mundo físicamente aislado que ya no existe. Esa asunción rota es la vulnerabilidad estructural central de la OT convergida.

Ubicación en el Programa: Este Documento N 12 inicia el tercer eje temático de la Unidad 3: las redes industriales y sus protocolos. Modbus es el primer protocolo en el programa por razones históricas, de prevalencia y pedagógicas: es el más simple, el más documentado y el que mejor ilustra las consecuencias de asumir un entorno físicamente aislado. El Documento N 13 analizará DNP3, un protocolo de mayor complejidad que incorpora algunas contramedidas de seguridad ausentes en Modbus. Juntos, estos dos documentos completan el eje de protocolos de la Unidad 3.

Objetivos de Aprendizaje

Al finalizar la lectura de este documento, el alumno será capaz de:

* Describir el contexto histórico de creación de Modbus y explicar por qué sus decisiones de diseño generan vulnerabilidades estructurales en entornos de convergencia IT/OT.
* Distinguir las tres variantes de Modbus (RTU, ASCII y TCP/IP) en términos de medio de transmisión, formato de trama, checksum y contexto de uso.
* Identificar y describir los cuatro tipos de datos del modelo de datos Modbus (coils, discrete inputs, input registers, holding registers) y su mapeo a los actuadores y sensores del proceso físico.
* Analizar la estructura PDU y ADU de una trama Modbus RTU e identificar los campos relevantes para la seguridad: dirección de esclavo, function code y datos.

* Identificar los function codes de mayor relevancia para la Ciberdefensa (FC01, FC02, FC03, FC04, FC05, FC06, FC15, FC16 y FC43) y describir el efecto físico sobre el proceso de una consulta maliciosa con cada uno.
* Analizar las vulnerabilidades estructurales de Modbus (ausencia de autenticación, ausencia de cifrado, replay attacks) y proponer las contramedidas de mitigación apropiadas para cada una.
* Interpretar una captura de tráfico Modbus TCP en Wireshark e identificar los campos de la PDU en la trama capturada.

1. Historia y Contexto de Diseño

Modbus fue desarrollado por Modicon (hoy Schneider Electric) en 1979 como protocolo de comunicación serial para sus controladores lógicos programables. Fue el primer protocolo industrial estandarizado publicado abiertamente, y esa apertura — junto con su simplicidad de implementación — fue la razón de su adopción masiva en la industria.

En 1979, el entorno de diseño de Modbus tenía las siguientes características:

* Conectividad física: los dispositivos Modbus se conectaban mediante cables RS-232 o RS-485 dentro de una instalación industrial. No existía el concepto de red IP ni de internet industrial.
* Operadores únicos: la instalación industrial era operada por una única organización. No existía la convergencia IT/OT ni el acceso remoto por redes corporativas.
* Amenaza exclusivamente física: el modelo de amenaza asumía que un actor malicioso necesitaba presencia física en la instalación para acceder al bus. La autenticación digital era considerada innecesaria.
* Recursos limitados: los PLCs de 1979 tenían capacidad de procesamiento y memoria extremadamente limitadas. Un protocolo de autenticación criptográfica habría sido computacionalmente imposible de implementar.

Las decisiones de diseño que resultan de este contexto son consistentes con sus premisas: Modbus es un protocolo extremadamente simple, sin autenticación, sin cifrado, sin control de acceso y sin registro de transacciones. Esas decisiones eran correctas en 1979. Son el problema central de la seguridad OT en 2026.

2. Las Tres Variantes de Modbus

Modbus existe en tres variantes que comparten el mismo modelo de datos y los mismos function codes, pero difieren en el medio de transmisión, el formato de la trama y el mecanismo de verificación de integridad:

Variante	Medio de transmisión	Formato de trama	Verificación de integridad	Puerto/velocidad típica	Contexto de uso predominante
Modbus RTU	Serial: RS-232 (punto a punto) o RS-485 (multipunto hasta 32 nodos)	Binario compacto. Los datos se transmiten como bytes sin separadores visibles entre campos.	CRC-16 (Cyclic Redundancy Check de 16 bits) al final de cada trama. Detecta errores de transmisión pero no autentifica al emisor.	9600 a 115200 bps	Sistemas legados. PLCs y RTUs en instalaciones industriales sin red IP. Redes de campo de largo alcance vía RS-485 (hasta 1200m).

Variante	Medio de transmisión	Formato de trama	Verificación de integridad	Puerto/velocidad típica	Contexto de uso predominante
Modbus ASCII	Serial: RS-232 o RS-485. Idéntico al RTU en medio físico.	Cada byte de datos se codifica como dos caracteres ASCII hexadecimales. La trama comienza con ":" y termina con CR+LF. Legible por humanos.	LRC (Longitudinal Redundancy Check): suma de todos los bytes de la trama (módulo 256), negada. Más débil que CRC-16.	9600 a 19200 bps (reducción de velocidad efectiva por el overhead ASCII)	Instalaciones antiguas donde la legibilidad humana de la trama era prioritaria. Menor prevalencia que RTU.
Modbus TCP/IP	Ethernet: red IP estándar. TCP puerto 502.	PDU Modbus encapsulada en un MBAP Header (Modbus Application Protocol Header) de 6 bytes.	Sin CRC ni LRC: la integridad la garantiza TCP. Sin autenticación de origen: cualquier cliente IP puede enviar requests.	TCP puerto 502, velocidades Ethernet estándar (100Mbps / 1Gbps)	La variante más prevalente en sistemas modernos y convergidos IT/OT. El vector de ataque remoto documentado en el caso Shodan.

Nota de Ciberdefensa -- La migración a TCP como multiplicador de exposición: La migración de Modbus RTU a Modbus TCP fue adoptada masivamente porque las redes Ethernet existentes en las plantas ya podían transportar tráfico Modbus sin nueva infraestructura. Sin embargo, esa migración elevó radicalmente el perfil de exposición: Modbus RTU requiere acceso físico al cable serial (alcance máximo de 1200m dentro de la instalación); Modbus TCP es accesible desde cualquier nodo de la red IP a la que esté conectado el dispositivo -- y si ese dispositivo tiene conectividad directa o indirecta a internet, es accesible desde cualquier punto del planeta. La migración a TCP amplificó la escala del adversario potencial sin modificar en absoluto el protocolo, que sigue sin autenticación.

3. El Modelo de Datos Modbus

Modbus organiza los datos del dispositivo esclavo en cuatro tablas de datos estandarizadas. Cada tabla tiene una función específica y mapea a un tipo diferente de elemento físico del proceso industrial:

Tabla de datos	Tipo de dato	Acceso	Mapeo a elemento físico	Tamaño (bits)	Dirección de registro
Coils (Bobinas)	Discreto: 0 o 1	Lectura y escritura	Salidas digitales: relés, solenoides, válvulas on/off, motores (arranque/parada).	1 bit	`0x0000` – `0xFFFF`
Discrete Inputs (Entradas Discretas)	Discreto: 0 o 1	Solo lectura	Entradas digitales: sensores de posición, finales de carrera, botones, detectores de presencia.	1 bit	`0x0000` – `0xFFFF`
Input Registers (Registros de Entrada)	Entero 16 bits sin signo	Solo lectura	Entradas analógicas: valores de sensores (temperatura, presión, caudal, nivel) convertidos a valor numérico por el transmisor.	16 bits	`0x0000` – `0xFFFF`
Holding Registers	Entero 16 bits sin	Lectura y escritura	Parámetros de configuración del proceso: setpoints (temperatura	16 bits	`0x0000` – `0xFFFF`

Tabla de datos	Tipo de dato	Acceso	Mapeo a elemento físico	Tamaño (bits)	Dirección de registro
(Registros de Retención)	signo o con signo		objetivo, presión de consigna), parámetros PID, límites de alarma, modos de operación.		

Nota de Ciberdefensa -- Los Holding Registers como objetivo de ataque prioritario: Los Holding Registers son los registros de escritura de mayor impacto en la seguridad del proceso. Son los que almacenan los setpoints (valores de consigna) del proceso: la temperatura objetivo de un reactor, la presión de operación de una línea de gas, el nivel de dosificación de un reactivo químico. Un adversario que puede escribir en los Holding Registers puede modificar los parámetros de operación del proceso dentro de los rangos que el sistema de alarmas no detectará como anómalos -- exactamente la técnica descrita en el caso de apertura del Documento N 11. FC06 (Write Single Register) y FC16 (Write Multiple Registers) son los function codes que acceden a los Holding Registers y, por lo tanto, los de mayor potencial de impacto físico.

4. Estructura de la Trama: PDU y ADU

El modelo de comunicación Modbus define dos niveles de empaquetamiento de datos:

La PDU (Protocol Data Unit) es el núcleo del protocolo y es común a las tres variantes (RTU, ASCII, TCP). Contiene solo dos campos:

Campo PDU	Tamaño	Descripción
Function Code	1 byte	Código de la operación solicitada. Define qué tipo de dato se lee o escribe y en qué tabla. Rango: 0x01 a 0x7F para códigos estándar. 0x80 a 0xFF indica respuesta de error (exception response).
Data	0 a 252 bytes	Contenido dependiente del function code. Para lecturas: dirección de inicio y cantidad de registros. Para escrituras: dirección de inicio, cantidad de registros y los valores a escribir.

La ADU (Application Data Unit) es la PDU envuelta en el header específico de cada variante:

Variante	Estructura ADU
Modbus RTU ADU	[Dirección esclavo: 1 byte] [Function Code: 1 byte] [Datos: 0-252 bytes] [CRC-16: 2 bytes]
Modbus ASCII ADU	[:] [Dirección esclavo: 2 chars hex] [Function Code: 2 chars hex] [Datos: N chars hex] [LRC: 2 chars hex] [CR] [LF]
Modbus TCP ADU (MBAP + PDU)	[Transaction ID: 2 bytes] [Protocol ID: 2 bytes (0x0000)] [Length: 2 bytes] [Unit ID: 1 byte] [Function Code: 1 byte] [Datos: 0-252 bytes]

4.1. Ejemplo de Trama Modbus RTU: FC03 Read Holding Registers

El siguiente ejemplo muestra una trama Modbus RTU de solicitud de lectura de holding registers (FC03). La trama es enviada por el master (MTU/PLC) al esclavo (PLC/RTU con dirección 01) para leer 2 registros a partir de la dirección 0x006B:

```
Trama RTU de solicitud (Request):
```

```
01  03  00 6B  00 02  B5 D3
|   |   |       |       |_____ CRC-16 (2 bytes, LSB primero)
|   |   |       |_____________ Cantidad de registros a leer: 0x0002 = 2
|   |   |_____________________ Dirección inicial: 0x006B = registro 107
|   |_________________________ Function Code 03: Read Holding Registers
|_____________________________ Dirección del esclavo: 0x01
```

```
Trama RTU de respuesta (Response normal):
01  03  04  02 2B  00 00  B8 33
|   |   |   |       |       |___ CRC-16
|   |   |   |       |___________ Registro 108: valor 0x0000 = 0
|   |   |   |___________________ Registro 107: valor 0x022B = 555
|   |   |_____________________ Byte count: 04 (2 registros x 2 bytes)
|   |_________________________ Function Code echo: 03
|_____________________________ Dirección del esclavo: 01
```

```
Trama RTU de respuesta (Exception response -- error):
01  83  02  C0 F1
|   |   |   |_____ CRC-16
|   |   |_________ Exception Code 02: Illegal Data Address
|   |_____________ Function Code + 0x80: 0x03 | 0x80 = 0x83
|_________________ Dirección del esclavo: 01
```

Nota de Ciberdefensa -- Las tramas de error como técnica de reconocimiento: Las exception responses de Modbus (function code | 0x80) revelan información sobre la configuración del dispositivo. Un adversario que recibe un Exception Code 02 (Illegal Data Address) para una consulta a la dirección X sabe que esa dirección no existe en el dispositivo. Sistematizando consultas con direcciones crecientes y registrando las respuestas, puede construir un mapa completo del espacio de direcciones del dispositivo -- que tablas tiene, cuantos registros contiene cada una -- sin necesidad de documentación del fabricante. Esta técnica de reconocimiento pasiva mediante exception responses es detectable solo si existe un IDS OT configurado para identificar patrones de escaneo de direcciones Modbus.

5. Function Codes de Mayor Relevancia para la Ciberdefensa

Los function codes son el mecanismo central de Modbus: determinan que operación se realiza sobre que tabla de datos. La siguiente tabla sistematiza los function codes más relevantes desde la perspectiva de la seguridad, indicando para cada uno el impacto potencial de una solicitud maliciosa:

FC (hex)	Nombre	Tabla afectada	Operación	Impacto de solicitud maliciosa
FC01 (0x01)	Read Coils	Coils	Lectura	Reconocimiento: revela el estado actual de todas las salidas digitales del dispositivo (válvulas abiertas/cerradas, motores en marcha/parados). Permite al adversario aprender el estado operativo normal del proceso.
FC02 (0x02)	Read Discrete Inputs	Discrete Inputs	Lectura	Reconocimiento: revela el estado de las entradas digitales (sensores de posición, detectores). Complementa FC01 para mapear el proceso.
FC03 (0x03)	Read Holding Registers	Holding Registers	Lectura	Reconocimiento de alta valor: revela los setpoints actuales del proceso (temperatura objetivo, presión de consigna, límites de alarma). Con este conocimiento, el adversario puede diseñar modificaciones que permanezcan dentro de los umbrales de alarma actuales.

FC (hex)	Nombre	Tabla afectada	Operación	Impacto de solicitud maliciosa
FC04 (0x04)	Read Input Registers	Input Registers	Lectura	Reconocimiento del proceso físico: revela los valores actuales de los sensores (temperatura real, presión real, caudal real). Permite al adversario verificar el estado del proceso en tiempo real sin acceso a la HMI.
FC05 (0x05)	Write Single Coil	Coils	Escritura (1 coil)	Acción directa sobre el proceso físico: puede abrir o cerrar una válvula, arrancar o detener un motor, activar o desactivar cualquier salida digital del PLC. Impacto inmediato y físicamente verificable.
FC06 (0x06)	Write Single Holding Register	Holding Registers	Escritura (1 registro)	Modificación de un setpoint o parámetro de proceso: cambia la temperatura objetivo, la presión de consigna o cualquier parámetro de control en un solo registro. El impacto puede ser inmediato (si el PLC actúa sobre el nuevo setpoint en el siguiente ciclo de scan) o diferido (si el proceso tarda en responder al nuevo valor).
FC15 (0x0F)	Write Multiple Coils	Coils	Escritura (N coils)	Acción masiva simultánea: puede cambiar el estado de múltiples salidas digitales en una sola trama. Permite deshabilitar simultáneamente un grupo completo de válvulas o motores de protección, o activar una secuencia de actuadores que individualmente son inofensivos pero en combinación producen una condición peligrosa.
FC16 (0x10)	Write Multiple Holding Registers	Holding Registers	Escritura (N registros)	El function code de mayor potencial de impacto: modifica múltiples setpoints y parámetros de proceso en una única operación. Puede reconfiguraciones completas del perfil operativo del proceso en milisegundos, antes de que el operador tenga tiempo de reaccionar.
FC43 (0x2B)	Read Device Identification	N/A	Lectura de metadata	Reconocimiento del dispositivo: revela el fabricante, el modelo, la versión de firmware y el nombre del dispositivo. Permite al adversario identificar el dispositivo exacto para buscar vulnerabilidades específicas del modelo en bases de datos públicas (ICS-CERT advisories, Shodan CVE feeds).

6. Vulnerabilidades Estructurales de Modbus

Las vulnerabilidades de Modbus no son errores de implementación que puedan ser corregidos con un parche: son decisiones de diseño que reflejan las premisas del entorno para el que fue creado. Comprender esta distinción es fundamental para la Ciberdefensa: no existe una versión “segura” de Modbus que preserva la misma simplicidad y compatibilidad; la seguridad debe agregarse en capas externas al protocolo.

Vulnerabilidad estructural	Descripción técnica	Ataque que habilita	Contramedida aplicable
Ausencia total de autenticación	Modbus no tiene ningún mecanismo para verificar que el master que envía una solicitud es el master autorizado. Cualquier	Man-in-the-Middle: un adversario en la red puede enviar comandos FC05/FC06/FC15/FC16 al PLC o RTU haciéndose pasar por el MTU legítimo. El esclavo no puede	Segmentación de red: aislar los dispositivos Modbus en una VLAN dedicada con acceso controlado. IDS OT para detectar masters no

Vulnerabilidad estructural	Descripción técnica	Ataque que habilita	Contramedida aplicable
	dispositivo en la red que conoce la dirección del esclavo y el formato del protocolo puede enviar solicitudes y recibirá respuestas válidas.	distinguir entre el master real y el adversario.	autorizados. No existe solución a nivel del protocolo en Modbus estándar.
Ausencia de cifrado	Todo el tráfico Modbus -- incluyendo los valores de los registros y las operaciones de escritura -- se transmite en texto claro sin cifrado. En Modbus RTU/ASCII la intercepción requiere acceso físico al cable; en Modbus TCP la intercepción es posible desde cualquier nodo de la red.	Eavesdropping (escucha pasiva): un adversario con acceso de red pasivo puede monitorear todo el tráfico Modbus, aprendiendo el estado del proceso en tiempo real y los comandos que el MTU envía a los dispositivos de campo, sin producir ningún tráfico propio que sea detectable.	Modbus sobre TLS (Modbus/TCP TLS, RFC 9042 / IEC 62351-3): encapsula Modbus TCP en una sesión TLS autenticada y cifrada. Requiere soporte del dispositivo esclavo (disponible en hardware moderno; no retrocompatible con hardware legacy).
Sin autorización por función ni por registro	Modbus no tiene control de acceso granular: si un dispositivo puede enviar solicitudes al esclavo, puede ejecutar cualquier function code sobre cualquier registro. No es posible, a nivel de protocolo, autorizar a un master solo para FC03 (lectura) pero no para FC06 (escritura).	Escalada de privilegios implícita: un sistema de reportes que solo debería leer datos del proceso (FC03/FC04) pero tiene conectividad de red al dispositivo Modbus puede, si es comprometido, enviar escrituras (FC05/FC06/FC15/FC16) que el protocolo aceptará sin restricción.	Firewall industrial (Deep Packet Inspection de Modbus): un firewall industrial que inspecciona el contenido de las tramas Modbus puede aplicar políticas de acceso por function code: permitir FC01-FC04 desde el sistema de reportes y bloquear FC05-FC16 desde la misma fuente. Solo los dispositivos master autorizados para escritura reciben ese acceso.
Vulnerabilidad a replay attacks	Modbus no incluye mecanismos anti-replay: no hay número de secuencia por sesión, no hay timestamp, no hay nonce. Una trama Modbus capturada del tráfico legítimo puede ser retransmitida horas o días después y será procesada por el esclavo exactamente igual que si la hubiera enviado el master original.	Replay attack: un adversario que capturó una trama FC05 legítima de apertura de una válvula puede retransmitir esa trama en cualquier momento posterior. El esclavo la ejecutará. El replay puede activarse en el momento tácticamente más efectivo -- por ejemplo, cuando el operador acaba de cerrar la válvula manualmente para responder a una emergencia.	Modbus sobre TLS incluye protección anti-replay mediante los mecanismos de TLS. En sistemas sin TLS: monitoreo de IDS para detectar retransmisiones exactas de tramas previas. La segmentación estricta de red reduce la superficie de captura del adversario.
Sin registro ni auditoría nativa	Modbus no incluye ningún mecanismo de registro de	Anti-forense: un adversario que modifica setpoints vía Modbus no deja registro en el protocolo de esa	Registro externo mediante proxy Modbus o IDS OT: un dispositivo

Vulnerabilidad estructural	Descripción técnica	Ataque que habilita	Contramedida aplicable
	transacciones: las operaciones de escritura sobre coils o registros no producen ninguna entrada de auditoría en el protocolo. El PLC o RTU esclavo ejecuta las escrituras sin registro del origen, el timestamp o el valor anterior.	acción. La única evidencia disponible es indirecta: los datos del historian SCADA que registran el cambio en el valor del holding register, si ese registro existe y no fue manipulado.	proxy interpuesto entre el MTU y los esclavos puede registrar todas las transacciones Modbus con timestamp, IP de origen, function code y datos. Este registro externo es independiente del protocolo y no puede ser eliminado manipulando el esclavo.

7. Modbus TCP y Shodan: La Exposición Pública

El motor de búsqueda Shodan indexa dispositivos conectados a internet identificándolos por los banners y respuestas que producen en puertos estándar. El puerto TCP 502 (Modbus) es monitoreado por Shodan, y los dispositivos Modbus TCP que tienen conectividad a internet -- ya sea directa o a través de routers industriales con NAT mal configurado -- son detectados e indexados.

Para identificar si un dispositivo Modbus está expuesto, Shodan envía una solicitud Modbus TCP con FC43 (Read Device Identification). Los dispositivos que responden revelan inmediatamente su fabricante, modelo y versión de firmware. Esta información es suficiente para que un adversario busque en la base de datos ICS-CERT los CVEs (Common Vulnerabilities and Exposures) del modelo específico.

Referencia al Caso Real (Positive Technologies, 2015 / Shodan): El estudio de Positive Technologies identificó dispositivos Modbus TCP accesibles públicamente desde internet que pertenecían a: plantas de tratamiento de agua en Estados Unidos, sistemas de control de edificios en universidades europeas, subestaciones eléctricas en países de Europa del Este, y sistemas de automatización de invernaderos agrícolas. Ninguno de estos dispositivos requería autenticación para recibir solicitudes de lectura (FC01-FC04). Algunos respondían a solicitudes de escritura (FC05/FC06) directamente desde internet. En ningún caso existía evidencia de que los operadores de esos sistemas supieran que sus dispositivos eran accesibles públicamente.

Nota de Ciberdefensa -- Shodan como herramienta de inteligencia bidireccional: Shodan es una herramienta legalmente disponible y ampliamente utilizada tanto por investigadores de seguridad como por actores maliciosos. Desde la perspectiva defensiva, el operador de una instalación industrial debería buscar sus propios activos en Shodan de forma proactiva: si un dispositivo industrial de la instalación aparece en Shodan con el puerto 502 abierto, esa es una vulnerabilidad crítica que requiere intervención inmediata. La búsqueda en Shodan de los rangos de IP de la organización debería ser parte del proceso periódico de gestión de la superficie de ataque en cualquier instalación con sistemas OT.

8. Lectura de Tráfico Modbus en Wireshark

Wireshark incluye un disector nativo de Modbus TCP que decodifica automáticamente las tramas Modbus encapsuladas en TCP y muestra los campos de la PDU de forma legible. Este conocimiento es práctico para el analista de Ciberdefensa que debe analizar capturas de tráfico de red en una investigación forense OT.

En el panel de Wireshark, una trama Modbus TCP se presenta en el árbol de protocolos como:

```
Frame N
  Ethernet II
```

```
Internet Protocol Versión 4, Src: 192.168.1.10, Dst: 192.168.1.20
Transmission Control Protocol, Src Port: 52341, Dst Port: 502
Modbus/TCP
  Transaction Identifier: 1
  Protocol Identifier: 0
  Length: 6
  Unit Identifier: 1
Modbus
  .011 0000 = Function Code: Read Holding Registers (3)
  Reference Number: 0x006B
  Word Count: 2
```

Para filtrar tráfico Modbus en Wireshark, los filtros de captura y visualización más útiles son:

* modbus: filtra todas las tramas del protocolo Modbus en el tráfico capturado.
* modbus.func_code == 6: filtra solo tramas FC06 (Write Single Holding Register), el function code de escritura de mayor interés forense.
* modbus.func_code >= 5: filtra todos los function codes de escritura (FC05 y superiores).
* modbus.reference_num: campo que contiene la dirección de inicio de la operación; útil para filtrar operaciones sobre un registro específico.
* tcp.port == 502 and tcp.flags.syn == 1: identifica nuevas conexiones TCP hacia el puerto Modbus, revelando cuando un nuevo cliente intentó conectarse al dispositivo.

Nota de Ciberdefensa -- Modbus TCP: detección de masters no autorizados: En un entorno con segmentación correcta, el único master autorizado para comunicarse con cada dispositivo Modbus TCP es el servidor MTU (o FEP) del SCADA. Si el análisis del tráfico capturado en Wireshark revela tramas Modbus originadas en una IP diferente a la del MTU autorizado, esa es evidencia de un master no autorizado. En la práctica forense, la primera consulta al archivo PCAP debe ser: “cuántas IP distintas originaron tráfico Modbus?”. Más de una IP de origen es una anomalía que requiere investigación.

9. Actividades de Verificación y Análisis

1. Análisis de Trama RTU: La siguiente trama Modbus RTU fue capturada en un bus RS-485 de una planta de tratamiento de agua: [01 10 00 60 00 03 06 00 0A 00 14 00 1E 55 BC]. Decodifique la trama identificando: (a) la dirección del esclavo, (b) el function code y su nombre, (c) la dirección de inicio de la operación, (d) la cantidad de registros afectados, (e) los valores escritos en cada registro y su posible interpretación como parámetro de proceso (expresándolos en decimal), y (f) el CRC de verificación. Justifique el impacto de seguridad de esta trama si fue enviada por un master no autorizado.
2. Modbus sin autenticación y escalada de riesgo: Un sistema de business intelligence corporativo necesita acceder a los datos de producción de una planta petroquímica para generar reportes de eficiencia energética. El arquitecto IT propone conectar el servidor de BI directamente a la red Modbus de la planta, configurándolo como master para leer los Input Registers (FC04) de los sensores. Analice: (a) qué function codes podría ejecutar este servidor de BI sobre los dispositivos Modbus si el servidor es comprometido por un adversario, (b) por qué el protocolo Modbus no puede distinguir entre un FC04 legítimo del BI y un FC16 malicioso del mismo servidor una vez comprometido, (c) qué arquitectura de red alternativa permitiría al servidor de BI acceder a los datos de producción sin conectividad directa a la red Modbus, y (d) qué función cumpliría un firewall industrial con DPI de Modbus en la solución propuesta.
3. Shodan y la gestión de la superficie de ataque: Como analista de Ciberdefensa de una empresa de distribución de agua, su gerente le pide un proceso para verificar si los dispositivos Modbus de la empresa están expuestos públicamente en internet. Describa: (a) la consulta de Shodan que utilizaría para buscar dispositivos de la empresa (incluyendo el

formato de la búsqueda por rango de IPs y por puerto), (b) qué información revelaría un dispositivo Modbus expuesto que responde a FC43 y que hace con esa información un adversario, (c) qué acción técnica inmediata tomaría si encontrara uno de sus dispositivos indexado en Shodan con el puerto 502 abierto, y (d) cómo incorporaría la búsqueda periódica en Shodan en el proceso de gestión de la superficie de ataque de la organización.

4. Análisis Forense Modbus -- Caso Integrador: Durante la respuesta a un incidente en una planta petroquímica, el equipo forense captura un archivo PCAP de tráfico de red tomado en el switch que conecta el servidor MTU con los PLCs. El análisis en Wireshark revela: (a) tráfico Modbus TCP entre el MTU (192.168.10.5) y el PLC-01 (192.168.10.21) durante las 8 horas normales de operación -- exclusivamente FC03 y FC04; (b) a las 02:17:43, una secuencia de tramas FC16 desde la IP 192.168.10.45 (no registrada en el inventario de activos) hacia el PLC-01, escribiendo en los registros 0x0060 a 0x0065; (c) a las 02:18:15, alarmas en el SCADA por valores fuera de rango en las variables mapeadas a esos registros. Identifique: el tipo de ataque, el function code utilizado y su impacto, la técnica de detección que produjo la evidencia (el PCAP), que vulnerabilidad estructural de Modbus habilitó el ataque, y las contramedidas que habrían impedido o detectado el ataque antes de las 02:17:43.

10. Glosario Mínimo

* **ADU (Application Data Unit):** Unidad de datos del nivel de aplicación en Modbus: la PDU envuelta en el encabezado específico de cada variante del protocolo (RTU, ASCII o TCP). La ADU incluye la dirección del esclavo o el MBAP header y el mecanismo de verificación de integridad (CRC-16, LRC o TCP).
* **CRC-16:** Cyclic Redundancy Check de 16 bits. Mecanismo de detección de errores de transmisión utilizado por Modbus RTU. Calcula un valor de verificación sobre el contenido de la trama y lo adjunta al final. El receptor recalcula el CRC al recibir la trama y compara con el recibido. Detecta errores de transmisión, pero no autentica al emisor.
* **Function Code (FC):** Código de 1 byte que define la operación Modbus solicitada: que tabla de datos se accede (coils, discrete inputs, input registers, holding registers) y si la operación es de lectura o escritura. Los function codes de escritura (FC05, FC06, FC15, FC16) son los de mayor impacto potencial sobre el proceso físico.
* **Holding Registers:** Tabla de datos Modbus para valores de 16 bits de lectura/escritura. Almacena setpoints, parámetros de control PID y límites de alarma del proceso. El function code FC06 escribe un único holding register; FC16 escribe múltiples. Son el objetivo de ataque de mayor impacto en Modbus.
* **MBAP Header:** Modbus Application Protocol Header. Encabezado de 7 bytes (6 de header + 1 de Unit ID) específico de Modbus TCP. Incluye el Transaction Identifier (número de secuencia de la transacción TCP) y el Protocol Identifier (siempre 0x0000 para Modbus). NO incluye autenticación.
* **Modbus TCP/IP:** Variante de Modbus que encapsula la PDU Modbus en un encabezado MBAP y la transporta sobre TCP/IP en el puerto 502. Sin CRC (la integridad la garantiza TCP) pero también sin autenticación de origen: cualquier nodo de la red IP puede enviar solicitudes al dispositivo esclavo.
* **PDU (Protocol Data Unit):** Núcleo del protocolo Modbus, común a las tres variantes (RTU, ASCII, TCP). Contiene exactamente dos campos: el Function Code (1 byte) y los Datos (0-252 bytes). La PDU es idéntica en las tres variantes; las ADUs difieren en sus headers.
* **Replay Attack:** Ataque en el que el adversario captura una trama válida del tráfico legítimo y la retransmite posteriormente para que el receptor la ejecute como si fuera un nuevo comando del master autorizado. Posible en Modbus porque el protocolo no incluye número de secuencia, timestamp ni nonce que permitan detectar retransmisiones.
* **Shodan:** Motor de búsqueda especializado en dispositivos conectados a internet identificados por los banners y respuestas en puertos específicos. Indexa dispositivos

Modbus TCP (puerto 502) que son accesibles públicamente desde internet. Herramienta utilizada tanto por investigadores de seguridad como por actores maliciosos para identificar dispositivos industriales expuestos.

11. Referencias Bibliograficas

Modbus Organization (2012). Modbus Application Protocol Specification V1.1b3. Hopkinton, MA: Modbus-IDA. (Capítulo 4: Function Codes -- pp. 11-20; Capítulo 5: Protocol Specification; disponible en https://modbus.org/docs/Modbus_Application_Protocol_V1_1b3.pdf).

Knapp, E. D., & Langill, J. T. (2015). Industrial Network Security: Securing Critical Infrastructure Networks for Smart Grid, SCADA, and Other Industrial Control Systems (2da ed.). Waltham, MA: Syngress. (Capítulo 3: Industrial Protocols -- sección Modbus, pp. 67-90).

Stouffer, K., Pease, M., Tang, C., Zimmerman, T., Pillitteri, V., & Lightman, S. (2023). Guide to Operational Technology (OT) Security (NIST Special Publication 800-82 Revisión 3). Gaithersburg, MD: NIST. (Sección 2.5: Network Protocols -- subsección Modbus).

Positive Technologies (2015). Vulnerabilities in Industrial Control Systems. Moscou: Positive Technologies. (Análisis de exposición de dispositivos Modbus TCP en internet vía Shodan; cuantificación de dispositivos accesibles públicamente sin autenticación).

Galloway, B., & Hancke, G. P. (2013). Introduction to Industrial Control Networks. IEEE Communications Surveys & Tutorials, 15(2), 860-880. (Sección sobre Modbus: historia, modelo de datos y comparación con DNP3).

RFC 9042 (2021). Secure Transport for Modbus (Modbus over TLS). IETF. (Especificación del perfil de seguridad TLS para Modbus TCP: autenticación mutua con X.509, protección anti-replay).

Catedra Tecnología Operativa (2026). Ficha de Catedra N 2: Arquitecturas en Sectores Críticos (BMS, Transporte y Accesos). FADENA.